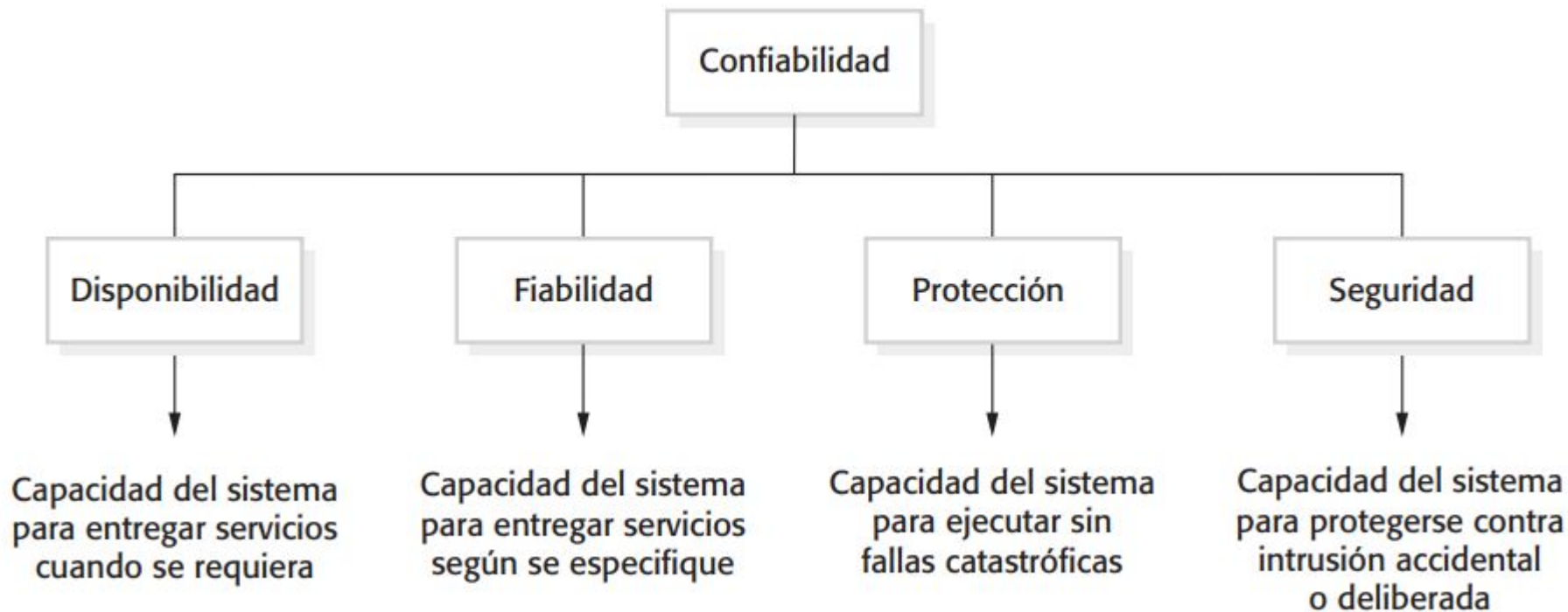

Confiabilidad - Seguridad

— INFO 248 —

Dra. Valeria Henríquez

Componentes de la Confiabilidad



La probabilidad de que en un momento dado el sistema funcionará, ejecutará y ofrecerá servicios útiles a los usuarios.

Disponibilidad

Capacidad del sistema para entregar servicios cuando se requiera

La probabilidad, durante un tiempo determinado, de que el sistema brindará correctamente servicios cómo espera el usuario

Fiabilidad

Capacidad del sistema para entregar servicios según se especifique

Seguridad

Cuán probable es que el sistema causará daños a las personas o su ambiente

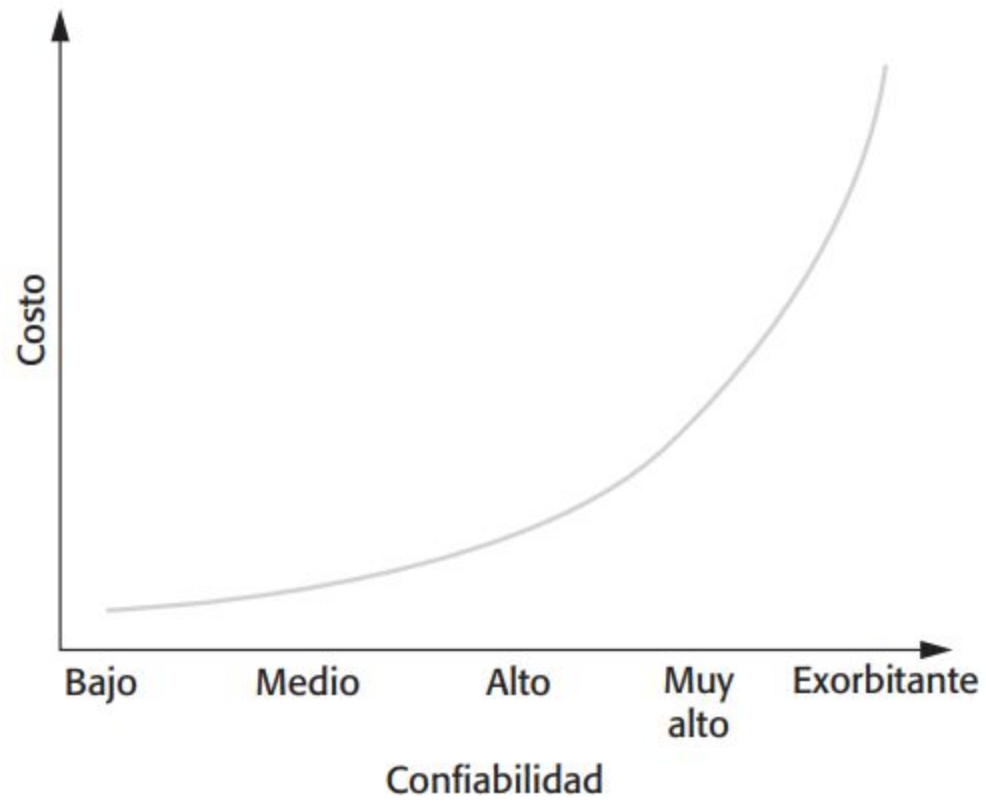
Protección

Capacidad del sistema para ejecutar sin fallas catastróficas

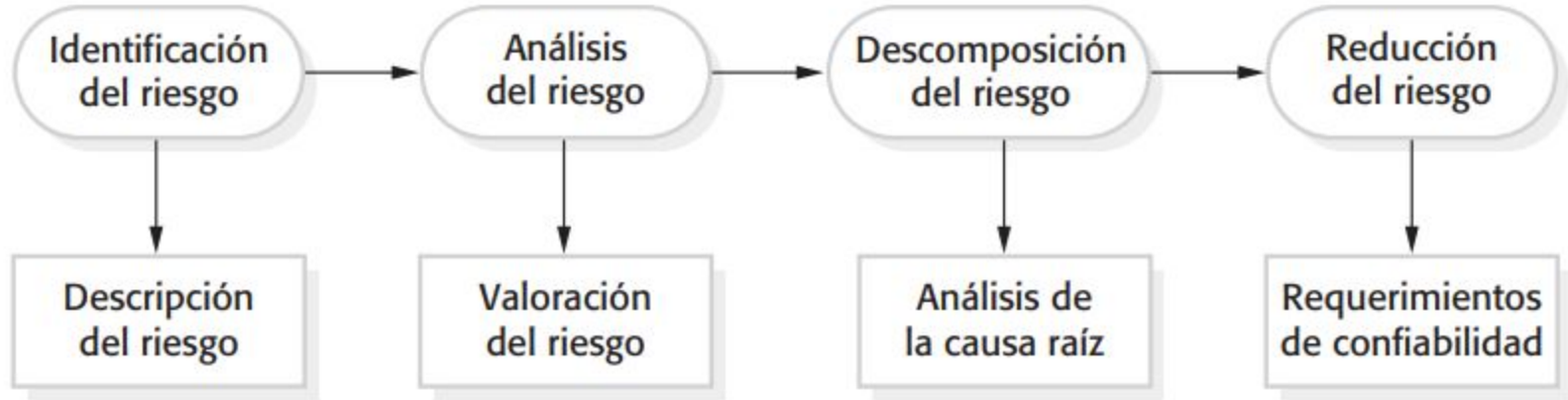
Cuán probable es que el sistema pueda resistir intrusiones accidentales o deliberadas

Seguridad

Capacidad del sistema para protegerse contra intrusión accidental o deliberada



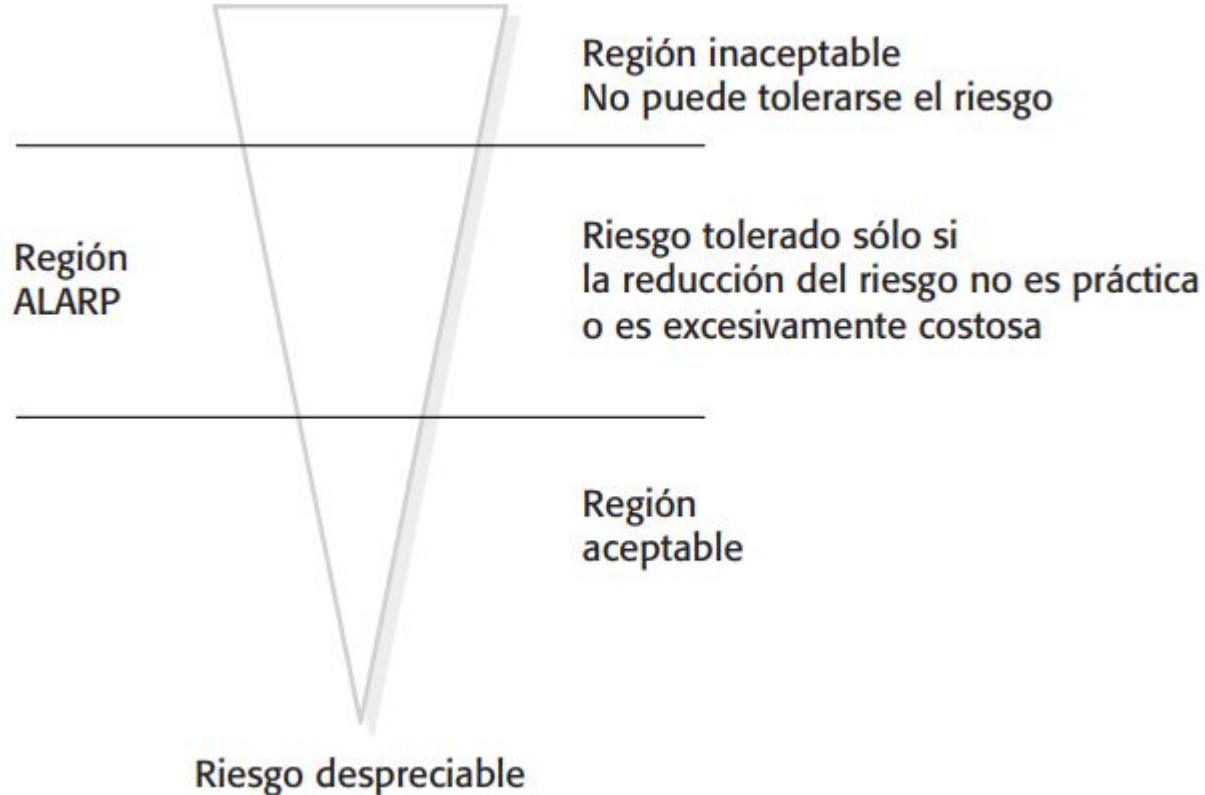
Especificación dirigida por riesgos



Especificación dirigida por riesgos

1. **Identificación del riesgo.** Se identifican los **riesgos potenciales al sistema. Éstos dependen del entorno en que se usa el sistema, o surgir riesgos de interacciones entre el sistema y las condiciones extrañas de su entorno operacional.** El accidente de Varsovia ocurrió cuando vientos cruzados generados durante una tormenta produjeron (inusualmente) que el avión se inclinara de modo que aterrizó sobre una rueda en lugar de dos.
2. **Análisis y clasificación del riesgo.** Cada riesgo se considera por separado. **Aquéllos potencialmente serios y no improbables se seleccionan para un mayor análisis.** En esta etapa, los riesgos pueden eliminarse porque es improbable que surjan o porque no se pueden detectar con el software (por ejemplo, una reacción alérgica al sensor en el sistema de bomba de insulina).
3. **Descomposición del riesgo.** Cada riesgo se analiza para descubrir las causas raíz potenciales de dicho riesgo. Dichas causas son las **razones por las que es posible que falle un sistema.** Pueden ser errores de software, hardware o vulnerabilidades inherentes que son consecuencia de decisiones de diseño del sistema.
4. **Reducción del riesgo.** Se hacen proposiciones de **formas para reducir o eliminar los riesgos** identificados. Ello contribuye con los requerimientos de confiabilidad del sistema que definen las defensas contra el riesgo y cómo se manejará éste.

Valoración del peligro



Caso Hipotético

Sistema automático con sensores que regulan por software la administración de insulina a pacientes.

¿Qué problemas de disponibilidad y fiabilidad visualizamos?

Peligro identificado	Probabilidad del riesgo	Severidad del accidente	Riesgo estimado	Aceptabilidad
1. Cálculo de sobredosis insulina	Media	Alta	Alto	Intolerable
2. Cálculo de subdosis insulina	Media	Baja	Bajo	Aceptable
3. Falla del sistema de monitorización del hardware	Media	Media	Bajo	ALARP
4. Falla de energía	Alta	Baja	Bajo	Aceptable
5. Máquina ajustada incorrectamente	Alta	Alta	Alto	Intolerable
6. Máquina que se descompone en el paciente	Baja	Alta	Medio	ALARP
7. Máquina que causa infección	Media	Media	Medio	ALARP
8. Interferencia eléctrica	Baja	Alta	Medio	ALARP
9. Reacción alérgica	Baja	Baja	Bajo	Aceptable

Ejemplo de árbol de fallas - Causa Raíz



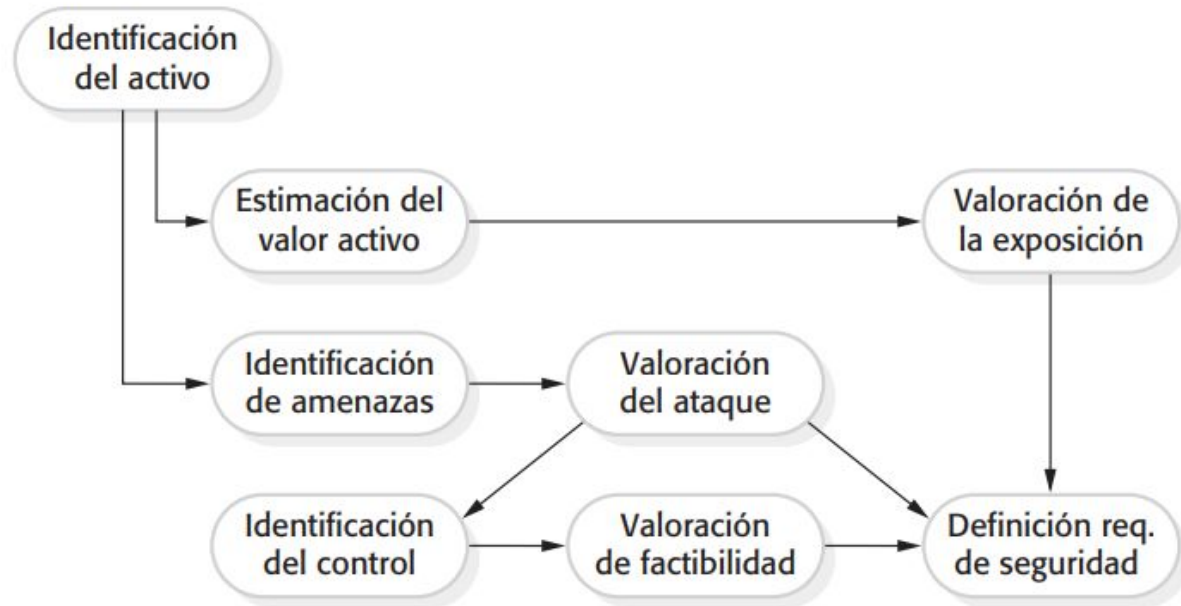
¿Cómo se construye ese árbol?

La técnica de los **5 porqués** es una herramienta de análisis causal que consiste en preguntar repetidamente “¿**por qué** ocurrió **esto?**” hasta llegar a la **causa raíz** de un problema, en lugar de quedarse solo con el síntoma visible.

Se usa en gestión de riesgos, mejora de procesos y resolución de problemas porque ayuda a identificar **qué falló realmente** y qué acciones se pueden tomar para evitar que vuelva a ocurrir.

Pregunta	Respuesta
1. ¿Por qué me fue mal en la prueba de INFO248?	Porque no pude resolver bien los ejercicios de modelado y diseño.
2. ¿Por qué no pude resolver bien los ejercicios?	Porque sabía repetir definiciones, pero me costó aplicarlas a un caso concreto.
3. ¿Por qué solo sabía repetir definiciones?	Porque estudié leyendo las diapositivas la noche anterior y subrayando cosas.
4. ¿Por qué estudié recién la noche anterior?	Porque pensé: “si entiendo los ejemplos de la clase, estoy listo”. Spoiler: no estaba listo.
5. ¿Por qué pensé eso?	Porque no identifiqué como riesgo que la prueba evaluaría aplicación, análisis y toma de decisiones, no solo memoria.

Proceso de valoración preliminar del riesgo para requerimientos de seguridad



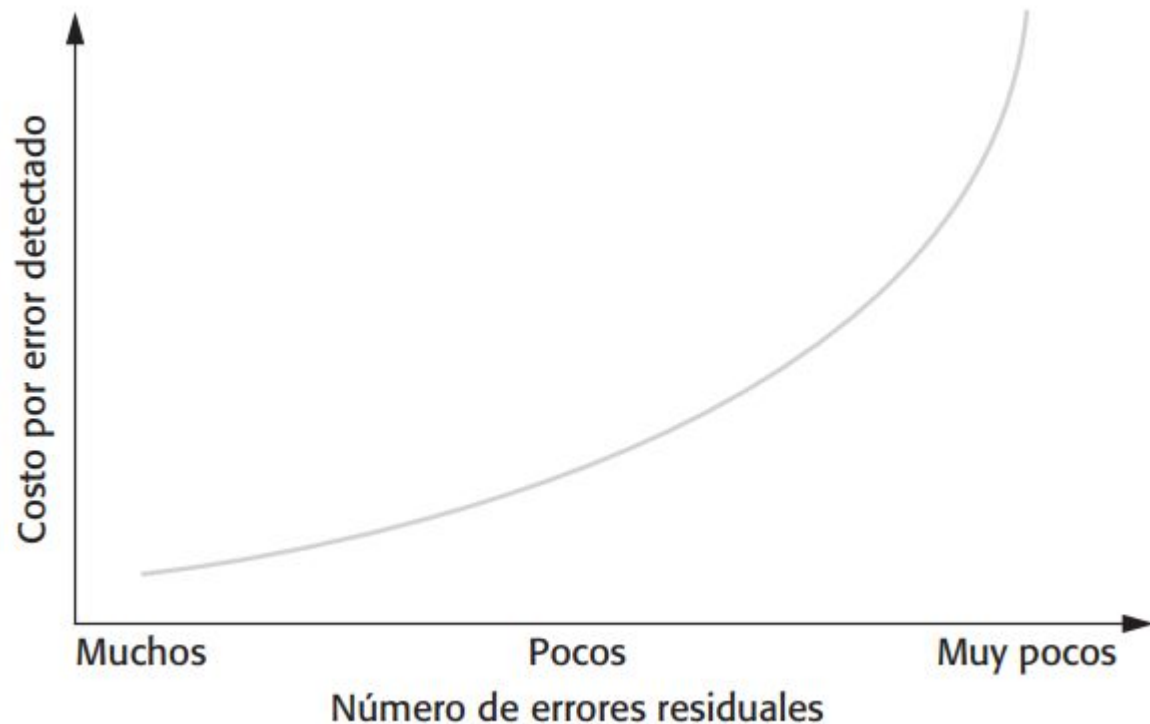
Caso Hipotético

Sistema de manejo de fichas de pacientes.

¿Qué activos pueden ser atacados?

Activo	Valor	Exposición
El sistema de información	Alto. Requerido para apoyar todas las consultas clínicas. Es potencialmente crítico para la seguridad.	Alta. Pérdidas financieras ya que es posible que deban cerrarse clínicas. Costos de sistemas de restauración. Posible daño al paciente si no logran prescribirse tratamientos.
La base de datos de pacientes	Alto. Requerido para apoyar todas las consultas clínicas. Es potencialmente crítico para la seguridad.	Alta. Pérdidas financieras, pues es posible que deban cerrarse clínicas. Costos de sistemas de restauración. Posible daño al paciente si no se prescriben tratamientos.
Un registro de paciente individual	Normalmente bajo, aunque puede ser alto para pacientes específicos de perfil alto.	Pérdidas directas bajas, aunque es posible la pérdida de reputación.

Conforme el software se vuelve más confiable, es necesario emplear mayor tiempo y esfuerzo para encontrar cada vez menos fallas



Seis mitos en seguridad

Seguridad al 100%



Seguridad "Next"



**El framework trae
seguridad integrada!!!**

Nunca nos han atacado



**No nos han atacado
aún!!!**

Tenemos un firewall



Y qué más??

Los ataques sólo vienen de fuera:

La incidencia de ataques desde dentro de la organización bordea el 20%

Y pueden no necesariamente ser ataques

Los usuarios son el peor enemigo de una aplicación



Los ataques sólo vienen de fuera:

Los usuarios son más peligrosos que los mismos crackers:

- Curiosos
- Torpes
- Crédulos
- Malévolos
- Petulantes



Solo para "Hackers"



Checklist

Checklist de Seguridad

Autenticación y Autorización:

Implementar un sólido sistema de autenticación para usuarios. Ejemplo: Uso de autenticación de dos factores (2FA).

Establecer y verificar adecuadas políticas de autorización. Ejemplo: Asignar roles específicos y privilegios mínimos necesarios.

Aplicar políticas de contraseñas fuertes. Ejemplo: Requerir contraseñas con combinaciones de letras, números y caracteres especiales.

Gestión de Sesiones:

Implementar sesiones seguras con tokens únicos. Ejemplo: Generar tokens JWT (JSON Web Tokens) con tiempo de expiración.

Establecer tiempos de expiración para las sesiones. Ejemplo: Configurar sesiones para cerrarse automáticamente después de un período de inactividad.

Encriptación de Datos:

Utilizar protocolos seguros para la transmisión de datos. Ejemplo: HTTPS en comunicaciones web.

Encriptar datos sensibles almacenados en la base de datos. Ejemplo: Uso de algoritmos de encriptación AES para contraseñas, bcrypt o Argon2.

Manejo de Errores:

Personalizar mensajes de error sin revelar información sensible. Ejemplo: Mostrar mensajes genéricos al usuario y registrar detalles de error en los registros internos.

Protección contra Inyecciones:

Validar y "sanitizar" todas las entradas de usuario. Ejemplo: Filtrar y escapar caracteres especiales.

Utilizar mecanismos para evitar inyecciones SQL. Ejemplo: Utilizar consultas parametrizadas en lugar de concatenación de cadenas u ORM.

Checklist de Seguridad

Auditoría y Monitoreo:

Implementar registros detallados de actividades. Ejemplo: Registros de auditoría que registran acciones de usuarios y eventos del sistema.

Establecer alertas para detectar comportamientos anómalos. Ejemplo: Alertas por intentos de acceso no autorizados.

Actualizaciones:

Mantener todas las bibliotecas y frameworks actualizados o con versiones específicas definidas. Ejemplo: Utilizar herramientas de gestión de dependencias como npm, pip o Maven.

Seguridad en la Configuración:

Revisar y ajustar configuraciones predeterminadas de seguridad. Ejemplo: Deshabilitar servicios y funciones innecesarios; cambiar cuentas "root" o "admin" o url por defecto

Limitar el acceso a recursos y privilegios solo a lo necesario. Ejemplo: crear usuarios con los privilegios mínimos y no instalar todo con root

Pruebas de Seguridad:

Implementar análisis estático y dinámico de código. Ejemplo: Utilizar herramientas de análisis estático como SonarQube.

Gestión de Configuración:

Implementar un sistema de gestión de configuración para controlar cambios en el código y la infraestructura.

Establecer política de privacidad para el control de versiones. Pejm. mantener repositorios privados

Utilizar archivos de configuración no versionados para registrar variables de configuración y entorno

Instalación de Software Base:

Verificar la autenticidad de las fuentes de instalación antes de proceder.

Actividad

- Copie el checklist

<https://docs.google.com/spreadsheets/d/1fFJxr3CsB5oqRsr40SO7i4dmgzfEAcwM1XwpCn8KIWc/edit?usp=sharing>

- Especifique cuáles podría validar y cómo hacerlo

